Marco legal y cumplimiento de TalentPact

Oct 12, 2026 · @xavier

Resumen

TalentPact es un sistema de IA de **alto riesgo** del AI Act (selección de personal) que trata datos personales de candidatos, cobra a empresas y usa cámara: le aplican a la vez el RGPD y la LOPDGDD, el AI Act, la LSSI-CE, la normativa de cookies, la de igualdad de trato y la de pagos. El diseño ya cumple lo más difícil (anonimato, minimización, supervisión humana, trazabilidad); lo que falta es sobre todo documental y contractual.

Norma	Qué exige a TalentPact	Estado
RGPD + LOPDGDD	Base jurídica por tratamiento, información, derechos, EIPD, registro de actividades, contratos con encargados	Producto: hecho. Documentos: EIPD, RAT y DPA pendientes
AI Act (Reglamento 2024/1689)	Alto riesgo desde el 2 de diciembre de 2027; transparencia del chatbot y prohibición de inferir emociones ya en vigor	Transparencia y prohibiciones: hecho. Sistema de gestión de riesgos y documentación técnica: pendiente
LSSI-CE	Aviso legal con datos del titular (art. 10) y consentimiento de cookies (art. 22.2)	Cookies: hecho. Aviso legal: falta NIF, domicilio y registro
Igualdad y no discriminación	Que la evaluación no discrimine por sexo, edad, origen u otras causas	Anonimato por diseño: hecho. Auditoría de sesgo: pendiente
Pagos	Cobro por Stripe con autenticación reforzada; condiciones de contratación B2B; facturación e IVA	Cobro: hecho. Condiciones y facturación: pendiente
Accesibilidad	Ley 11/2023 para servicios a consumidores (exenta si TalentPact es microempresa)	A evaluar al constituir la sociedad

Este documento es una guía de trabajo, no asesoramiento jurídico: antes de operar con datos reales conviene que un abogado especializado revise la EIPD y los contratos.

Mapa normativo

Seis bloques de normas, de más a menos peso para el producto.

Norma	Artículos clave	Dónde toca a TalentPact
RGPD, Reglamento (UE) 2016/679	5 (principios), 6 (bases), 13 (información), 22 (decisiones automatizadas), 25 (privacidad por diseño), 28 (encargados), 30 (registro), 32 (seguridad), 33 (brechas, 72 h), 35 (EIPD), 44-49 (transferencias)	Perfiles, evaluaciones, cámara, contacto desbloqueado, pagos
LOPDGDD, Ley Orgánica 3/2018	Desarrolla el RGPD en España: edad mínima de consentimiento (14 años), derechos digitales	Registro de candidatos, comunicación de brechas a la AEPD
AI Act, Reglamento (UE) 2024/1689 modificado por el Reglamento (UE) 2026/1744	Anexo III punto 4.a (selección de personal = alto riesgo), art. 4 (alfabetización), art. 5 (prácticas prohibidas), arts. 9-17 (proveedor), art. 26 (responsable del despliegue), art. 50 (transparencia)	El corrector, el filtro de integridad y el chat de soporte
LSSI-CE, Ley 34/2002	Art. 10 (información del prestador), art. 21 (comunicaciones comerciales), art. 22.2 (cookies)	Aviso legal, banner de analítica, futuros correos
Igualdad de trato	Ley 15/2022 integral para la igualdad de trato; Estatuto de los Trabajadores, art. 4.2.c y 17	Que ni la rúbrica ni el filtro discriminen; el anonimato ayuda pero no basta
Pagos y contratación	PSD2 (autenticación reforzada, la gestiona Stripe), Código de Comercio y normativa de IVA y facturación	Desbloqueo de 49 €, planes y retos a medida

No aplican: MiCA (el SkillPass no es un criptoactivo: no se transmite ni tiene valor), NIS2 (TalentPact no es entidad esencial ni importante).

A estudiar con un abogado: la Ley 3/2023 de Empleo regula la intermediación laboral. Un portal que solo publica ofertas no es agencia de colocación, pero TalentPact evalúa y ordena candidatos para las empresas, y eso puede considerarse intermediación, que exige declaración responsable ante el servicio público de empleo. Al candidato, en ningún caso, se le puede cobrar por acceder a un empleo: el único cobro B2C (5 € por reto extra) es por práctica, no por intermediación.

RGPD en detalle

TalentPact es **responsable** de los datos de candidatos y empresas dentro de la plataforma. Cuando una empresa desbloquea un contacto, pasa a ser **responsable independiente** de ese dato desde ese momento: el contrato con empresas debe decirlo y obligarla a usarlo solo para ese proceso de selección.

Tratamientos y bases jurídicas

Tratamiento	Datos	Base jurídica (art. 6 RGPD)	Conservación propuesta
Cuenta y perfil del candidato	Email, nombre, teléfono, LinkedIn, sector, preferencias de empleo	Ejecución del contrato (6.1.b)	Mientras la cuenta exista; borrado completo al eliminarla (ya implementado)
Corrección con IA	Respuestas, notas, criterios, modelo usado	Ejecución del contrato (6.1.b) + garantías del art. 22	Notas: 2 años desde la última actividad. Texto de las respuestas: 12 meses
Integridad y cámara	Contadores de incidencias; el vídeo no se guarda	Consentimiento (6.1.a), revocable sin perder la prueba	Con la evaluación a la que acompañan
Pool anónimo	Alias, notas, condiciones, riesgo de integridad	Ejecución del contrato; el candidato puede ocultarse en cualquier momento	Mientras esté visible
Cesión del contacto tras el pago	Nombre, email, teléfono, LinkedIn	Consentimiento del candidato a recibir contactos (ajuste "Permitir contacto")	Registro de la cesión: 3 años (prescripción de infracciones muy graves en la LOPDGDD)

Tratamiento	Datos	Base jurídica (art. 6 RGPD)	Conservación propuesta
Empresas y facturación	Datos de contacto, pagos, facturas	Contrato (6.1.b) y obligación legal (6.1.c)	Facturas: 6 años (Código de Comercio, art. 30)
Analítica	Uso de la web	Consentimiento (art. 22.2 LSSI)	14 meses, configurable en Google Analytics
Chat de soporte	Mensajes	Interés legítimo en atender consultas (6.1.f)	6 meses

Decisiones automatizadas (art. 22). La nota de la IA influye en a quién contacta una empresa, así que se tratan con las garantías del art. 22.3 aunque la decisión final sea humana: informar de la lógica (rúbrica y escala), permitir pedir revisión humana y expresar el punto de vista, y que ninguna señal descarte a nadie de forma automática. El producto ya cumple la última; el botón de revisión está en la hoja de ruta.

Evaluación de impacto (art. 35). Obligatoria: evaluación sistemática de personas con IA que afecta a su acceso al empleo, más tratamiento de imagen. Debe estar hecha antes de tratar datos reales.

Encargados y transferencias internacionales. Supabase (base de datos, región UE), Netlify (alojamiento y funciones), Anthropic (corrección y chat) y Google (analítica) necesitan contrato de encargo (art. 28). Las tres últimas pueden tratar datos en EE. UU.: hay que comprobar que están adheridas al Marco de Privacidad de Datos UE-EE. UU. o firmar cláusulas contractuales tipo, y decirlo en la política de privacidad. Stripe actúa como responsable independiente de los datos de pago.

Brechas (arts. 33-34). Protocolo escrito: detectar, contener, notificar a la AEPD en 72 horas si hay riesgo y avisar a los afectados si el riesgo es alto. El registro de accesos al contacto (`contact_access`) ayuda a saber qué salió y a quién.

Delegado de protección de datos. Recomendable aunque quizá no obligatorio al empezar: la evaluación sistemática de candidatos a gran escala es uno de los supuestos del art. 37.

AI Act

TalentPact es **proveedor** de un sistema de alto riesgo: el anexo III, punto 4.a, incluye los sistemas de IA destinados a la selección de personas, en particular a analizar candidaturas y evaluar candidatos. Las empresas que lo usan son **responsables del despliegue** (art. 26). El Reglamento (UE) 2026/1744 retrasó las obligaciones de alto riesgo del anexo III al **2 de diciembre de 2027**; otras ya están en vigor.

Calendario

Desde	Obligación	Qué supone para TalentPact	Estado
2 de febrero de 2025	Prácticas prohibidas (art. 5), entre ellas inferir emociones en el trabajo	La cámara solo comprueba presencia, nunca expresiones	Cumplido
2 de febrero de 2025	Alfabetización en IA (art. 4), suavizada por el Reglamento 2026/1744	Formación básica del equipo y de las empresas clientes sobre límites del corrector	Pendiente: guía para empresas
2 de agosto de 2026	Transparencia (art. 50): avisar de que se habla con una IA	El chat de soporte se presenta como asistente con IA	Cumplido en esta revisión
2 de diciembre de 2027	Requisitos de alto riesgo (arts. 9-17, 43, 49, 72)	Ver la tabla siguiente	En preparación

Obligaciones de alto riesgo como proveedor

Artículo	Requisito	Lo que ya hay	Lo que falta
9	Sistema de gestión de riesgos	Banco de pruebas con κ, sesgo y bloqueo de inyección	Documento de riesgos con revisión periódica
10	Gobernanza de datos	Gold set etiquetado	Ampliarlo y medir sesgo por género, edad y lengua
11 y anexo IV	Documentación técnica (formulario simplificado para pymes)	Informe técnico y memoria del TFM	Redactarla en el formato del anexo IV
12	Registro automático de eventos	Recibo firmado por evaluación con modelo, versión y señales	Política de conservación (mínimo 6 meses)
13	Instrucciones de uso para las empresas	—	Guía de uso: qué mide la nota, límites, zona de duda

Artículo	Requisito	Lo que ya hay	Lo que falta
14	Supervisión humana	Nada descarta automáticamente; notas limitadas a revisión	Bandeja de revisión y botón de apelación
15	Exactitud, solidez, ciberseguridad	Corrector en servidor, filtro de inyección, recibos HMAC	Pruebas de solidez periódicas en CI
17	Sistema de gestión de la calidad	Tests automáticos	Procedimientos escritos de cambios del modelo y del prompt
43 y 49	Evaluación de conformidad (control interno para el anexo III) y registro en la base de datos de la UE	—	Antes de comercializar a partir de diciembre de 2027
72	Seguimiento poscomercialización	Panel de administración con métricas reales	Plan de seguimiento y notificación de incidentes graves

Lo que deben hacer las empresas (art. 26), y que TalentPact tiene que facilitarles: asignar supervisión humana competente, conservar los registros al menos 6 meses, informar a los candidatos de que se usa un sistema de IA y, si evalúan a su propia plantilla, informar antes a la representación legal de los trabajadores.

Cámara, integridad y SkillPass

Los tres elementos más delicados del producto están diseñados para quedarse del lado seguro de la ley: la cámara no identifica ni infiere emociones, la integridad nunca descarta sola y la blockchain solo guarda una huella.

Elemento	Límite legal	Cómo lo respeta el diseño
Cámara	El AI Act prohíbe inferir emociones en el trabajo (art. 5). La AEPD ha considerado no justificado el reconocimiento facial biométrico obligatorio en exámenes en línea y exige alternativas y consentimiento informado	Opcional y con consentimiento; el vídeo se analiza en el navegador y se descarta; solo comprueba presencia (luz, caras sí o no), nunca identidad ni expresiones; sin cámara la prueba vale igual
Informe de integridad	Art. 22 RGPD (decisiones automatizadas) y art. 14 AI Act (supervisión humana)	Riesgo bajo, medio o alto como señal para una persona; ninguna señal descarta a nadie
Filtro anti-manipulación	Proporcionalidad y transparencia	Las reglas se publican en la página legal; un ataque claro puntúa 0 y queda registrado; una señal leve solo limita la nota a 60 hasta revisión
SkillPass en blockchain	Derecho de supresión (art. 17) frente a un registro que no se puede borrar	En la cadena solo va el hash del documento; el documento vive fuera y se borra al eliminar la cuenta, y el hash queda sin significado
Cesión del contacto	Base jurídica y trazabilidad	Solo tras pago confirmado, solo si el candidato mantiene el permiso de contacto, y cada entrega queda registrada

Un matiz sobre la cámara: aunque el vídeo no salga del dispositivo, analizar la imagen de una persona es un tratamiento de datos. Por eso tiene base en el consentimiento y entra en la evaluación de impacto, aunque no sea un tratamiento de datos biométricos en el sentido del art. 9 RGPD, que exige que la imagen se use para identificar a alguien.

Documentos legales

Cuatro documentos ya están publicados en `legal.html`; el resto son internos o contractuales y deben estar listos antes de tratar datos reales. Cambia el estado de cada fila a medida que avancen.

Documento	Norma	Quién lo ve	Estado
Aviso legal con titular, NIF, domicilio y registro	LSSI-CE, art. 10	Público	Borrador
Política de privacidad (tratamientos, bases, plazos, encargados, derechos)	RGPD, arts. 13-14	Público	Publicado
Política de cookies y banner con "Rechazar" igual de fácil	LSSI-CE, art. 22.2	Público	Publicado
Información sobre la IA y la supervisión de pruebas	AI Act, arts. 26 y 50; RGPD, art. 22	Público	Publicado
Términos de uso para candidatos, aceptados al registrarse	Código Civil; LSSI-CE	Público	Borrador
Condiciones de contratación para empresas, con cláusula de responsable independiente sobre los contactos	RGPD, arts. 26-28	Empresas	Pendiente
Registro de actividades de tratamiento	RGPD, art. 30	Interno y AEPD	Pendiente
Evaluación de impacto (EIPD)	RGPD, art. 35	Interno y AEPD	Pendiente
Contratos de encargo con Supabase, Netlify, Anthropic y Google	RGPD, art. 28	Interno	Pendiente
Protocolo de brechas de seguridad	RGPD, arts. 33-34	Interno	Pendiente
Instrucciones de uso del sistema para empresas	AI Act, arts. 13 y 26	Empresas	Pendiente
Documentación técnica del sistema de alto riesgo	AI Act, art. 11 y anexo IV	Autoridad de vigilancia	Pendiente
Declaración responsable como agencia de colocación	Ley 3/2023 de Empleo	Servicio público de empleo	A estudiar

Los contratos de encargo no hay que redactarlos: Supabase, Netlify, Anthropic y Google ofrecen su DPA estándar, que basta con aceptar en el panel de cada proveedor y archivar.

Cambios hechos en el producto

En esta revisión el producto deja de tener contenido de ejemplo: todo lo que se ve sale de la base de datos o del corrector, y la interfaz pasa a una estética sobria de producto profesional.

Cumplimiento legal

Antes	Ahora
El chat de soporte no decía que era una IA	Se presenta como asistente con IA y advierte de que puede equivocarse (art. 50 AI Act)
El permiso "Permitir contacto" solo vivía en el navegador	El servidor lo comprueba: sin permiso no se cobra el desbloqueo ni se entrega el contacto, aunque hubiera pago previo (art. 7.3 RGPD)
La página legal hablaba de contenido de demostración y no mencionaba cámara, integridad ni cesiones	Nueva sección de supervisión de pruebas, tratamientos y plazos por dato, derecho a revisión humana y responsabilidad de la empresa sobre el contacto
La página legal prometía que la ortografía no penaliza, pero el corrector no lo decía	El corrector lo incluye en sus reglas, junto con la prohibición de suponer rasgos personales
Backoffice con contraseña en el código y datos inventados	Solo con rol `admin` asignado por el servidor; datos reales, agregados y sin datos personales de candidatos

Fin de lo demo

Antes	Ahora
22 ofertas y 6 empresas de ejemplo	Ofertas reales en Supabase (`list-jobs`, `save-job`); la empresa publica, cierra y reabre
8 candidatos de ejemplo y una ficha local "Tu perfil" en el pool	Solo el pool real de Supabase
Contacto generado a partir del id	Solo el contacto real tras pago confirmado
Ranking con tramos inventados ("Top 30 %")	Posición real entre los candidatos visibles del pool

Antes	Ahora
Candidatos por oferta calculados al azar e "importe acumulado (simulado)"	Candidatos del pool con al menos un 50 % de encaje e importe pagado según Stripe
Etiqueta "Versión preliminar" y avisos de correos que no se enviaban	Eliminados

Ficha de empresa. Las empresas pueden añadir descripción, sector, web y ubicación, que los candidatos ven en sus ofertas y en el listado de empresas.

Rediseño visual

- Tipografía Inter en toda la web, en lugar de Sora, Plus Jakarta Sans y una display decorativa.
- Unos 800 emojis sustituidos: iconos de línea en la interfaz y monogramas por categoría en los retos.
- Paleta sobria (tinta y verde azulado profundo), botones y tarjetas planos con bordes finos, chips rectangulares y neutros, y sin animaciones de aparición.
- Portada sin el lema en monoespaciada ni el titular tachado: "Contrata por habilidades demostradas, no por currículum".
- Textos corregidos: fuera "Success fee" y "Kill Switch", que no correspondían al producto.

Para activarlo en producción

1. Ejecutar en Supabase, por este orden: `supabase_schema_integrity.sql`, `supabase_schema_pool.sql` y `supabase_schema_jobs.sql`.
2. Asignar `app_metadata.role = admin` a la cuenta del backoffice desde Authentication → Users.
3. Desplegar web y funciones a la vez.

Fuentes

Consultadas para este documento

- AI Act, anexo III (versión de referencia): selección de personal como alto riesgo.
- AI Act, artículo 26: obligaciones de los responsables del despliegue, incluida la conservación de registros 6 meses.
- ActuIA, obligaciones del AI Act y el Reglamento 2026/1744: publicación el 24 de julio de 2026 y nuevo calendario.
- Gibson Dunn, acuerdo del ómnibus del AI Act: aplazamiento del anexo III al 2 de diciembre de 2027 y cambios en la alfabetización en IA.

- Ley 34/2002 (LSSI-CE), texto consolidado en el BOE: arts. 10 y 22.2.
- Economist & Jurist sobre el criterio de la AEPD y Genbeta sobre la supervisión de exámenes en línea (solo vistos en resultados de búsqueda): reconocimiento facial y cámaras en pruebas en línea.

Normas citadas por su texto oficial (no revisado en esta sesión)

- RGPD, Reglamento (UE) 2016/679
- LOPDGDD, Ley Orgánica 3/2018
- AI Act, Reglamento (UE) 2024/1689
- Ley 15/2022 integral para la igualdad de trato, Ley 3/2023 de Empleo, Ley 11/2023 de accesibilidad y Código de Comercio (art. 30)

La doctrina de la AEPD sobre supervisión de exámenes se ha tomado de resúmenes de prensa vistos en resultados de búsqueda, no de las páginas completas: conviene leer el informe original en aepd.es antes de cerrar la EIPD.